Lab 1 Foot-printing and Reconnaissance

Lab 1-o1 Gather Information using Advanced Google Hacking Techniques

> **Disclaimer : Using the notes is for educational prepose only, the owner is not responsible for any mis conduct by the reader**

Scenario:

You are an ethical hacker hired by XYZ.inc , a mid-sized technology company specializing in software development and IT solutions. Recently, XYZ experienced a surge in phishing attempts and unauthorized access attempts on its web application. A security audit revealed that attackers might have used publicly accessible pages and misconfigured directories on the company's website to gather sensitive information. This data potentially includes internal employee directories, customer service logs, and development files mistakenly exposed online. These files contained sensitive information, such as internal project details and credentials embedded in older scripts.
To prevent further reputational damage and ensure compliance with data protection regulations, the company's senior management has requested a proactive security assessment to identify exposed data accessible through search engines like Google. The goal is to identify sensitive pages indexed by Google Search, such as administrator login portals, internal documentation directories, and forgotten subdomains. They want you to simulate an attacker's perspective using Advanced Google Hacking Techniques—leveraging Google search operators to locate exposed information

Solution:

Phase 1: Document Scope and Understanding

This document outlines the critical observations from the reference scenario, focusing on the EC Council for practice purposes.

- **Increase in Phishing Attempts:** There has been a notable surge in phishing attempts targeting company email addresses. This suggests that the email accounts of internal

employees, which may be discoverable via professional networks like LinkedIn, are currently exposed to malicious actors.

- **Unidentified Unauthorized Access Attempts:** We have detected unauthorized access attempts. While the full scope and origin of these attempts are still under investigation, the evidence points to a potential attacker targeting the administrative login page and employing a series of brute-force attempts to gain entry.
- **Exposure of Sensitive Data:** A significant risk has been identified concerning potentially accessible sensitive information. This includes internal project details and hard-coded credentials found within legacy scripts. Such exposure could lead to a substantial breach of confidential data.

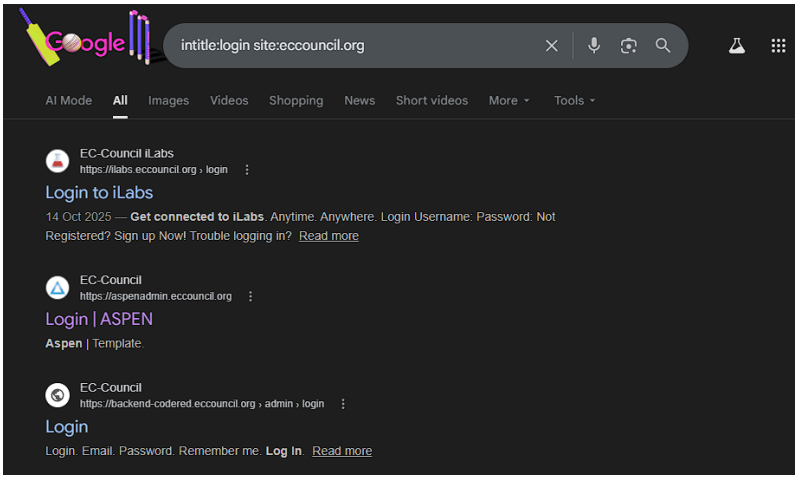
Phase 2: Reconnaissance and Login Page Enumeration

The initial phase of the assessment involves leveraging the Google Chrome browser to identify exposed administrative interfaces. The primary objective is to locate any index-parsing elements or URLs that host login portals within the target domain.

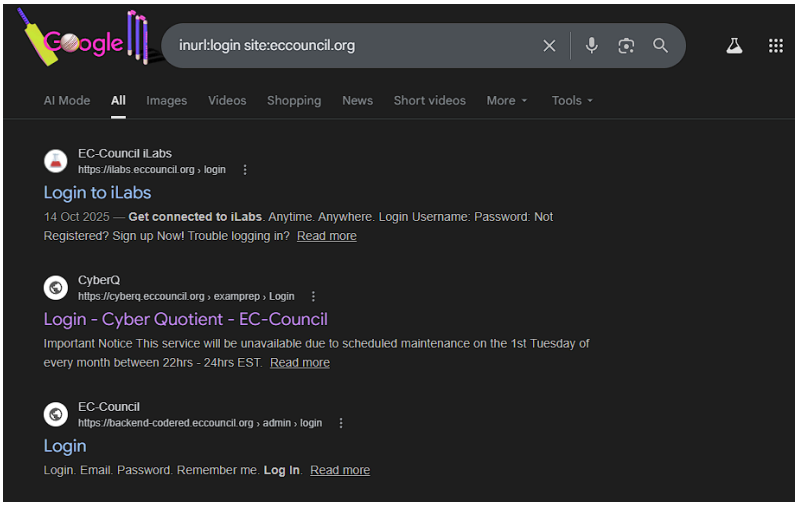
To systematically enumerate these entry points, the following Google dork queries were employed to filter and refine the search results:

```
intitle:login site:eccouncil.org
inurl:login site:eccouncil.org
```

These queries effectively narrow the reconnaissance scope by returning a concise list of potential authentication points within the `eccouncil.org` domain. By identifying these specific endpoints, we establish a foundation for subsequent testing phases, including credential validation and vulnerability assessment. Visual confirmation and further analysis of the findings are documented in the accompanying screenshot.



intitle:login site:eccouncil.org



inurl:login site:eccouncil.org

Following the identification of authentication portals, the next phase involves enumerating potential employee contacts to facilitate targeted phishing simulations. This process leverages advanced search operators to discover employee profiles and publicly available email addresses associated with the organization.

Search Query Methodology:

The following Google dork was utilized to identify specific employee references within the target domain's indexed content:

text

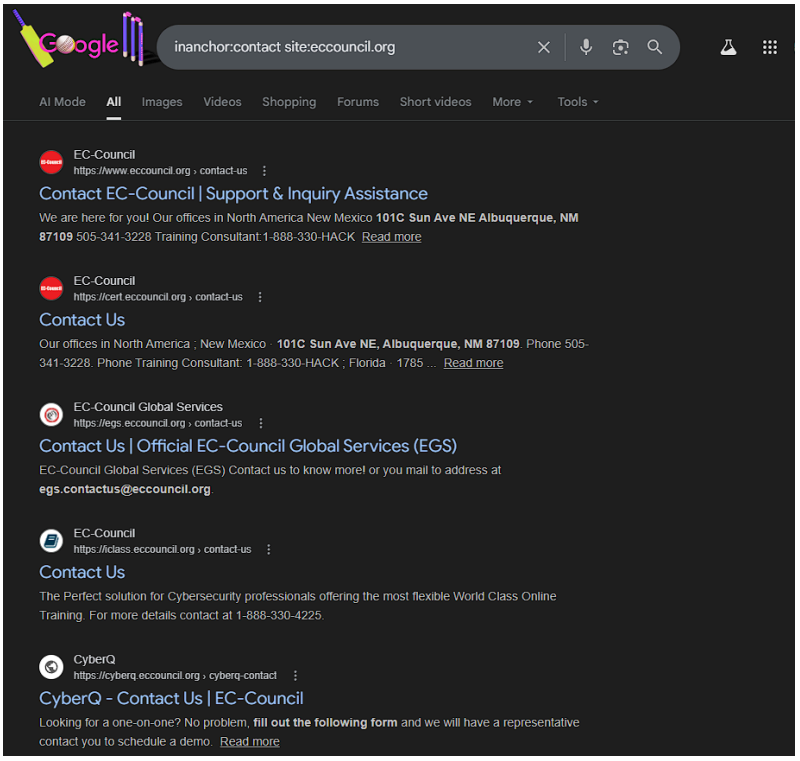
```
allinurl: EC-Council Tanya/Utkarsh
```

Rationale:

- Utilizing specific employee names (e.g., Tanya, Utkarsh) as search parameters can yield indexed pages, forum posts, or documentation where these individuals are referenced.
- Variations in search terms and name combinations may produce additional unstructured data points, revealing potential contact information or organizational roles.

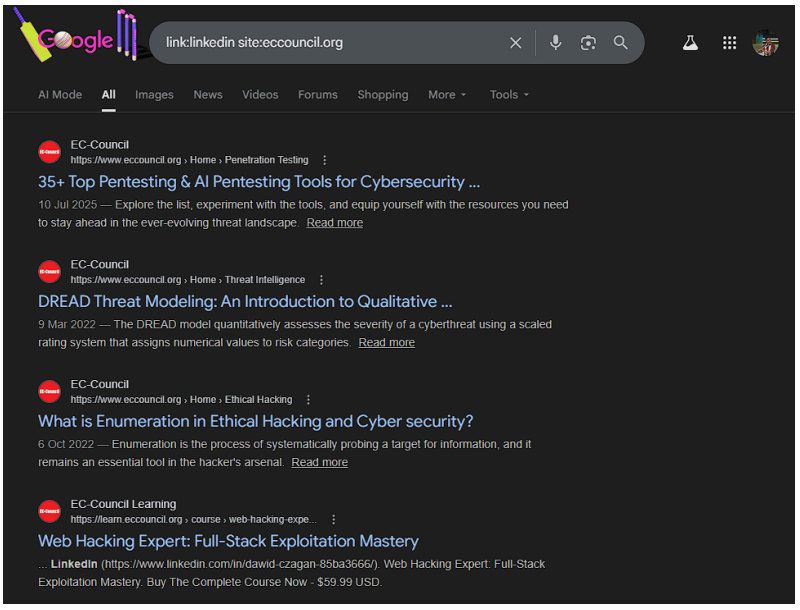
Further we can use inanchor:[subtext] to address what’s reflected in the anchor text of the sites

```
inanchor:contact site:eccouncil.org
```



Using Link:[subtext] can reveal the pointing reference links:

```
link:linkedin site:eccouncil.org
```



Related:[substring] will let you get through the site that are similar to the mentioned site. and mixing them with different dorks make the tester find good information

Or further we can use GHDB to query the dorks like:

Google Hacking Database

Filters | Reset All

Show 15

Quick Search user

Date Added	Dork	Category	Author
2024-01-23	(site:jsonformatter.org | site:codebeautify.org) & (intext:aws | intext:bucket | intext:password | intext:secret | intext:username)	Files Containing Juicy Info	letmewin cyber
2024-01-23	filetype:reg reg HKEY_CURRENT_USER SSHHOSTKEYS	Files Containing Juicy Info	web work
2023-12-21	intext:"user" filetype:php intext:"account" inurl:/admin	Files Containing Juicy Info	saurabh kode
2023-12-14	intext:"userfiles" intitle:"Index Of" site:*.com.*	Files Containing Juicy Info	J. Daniel Elias Valdez
2023-12-11	inurl:"UserLogin/" intitle:"Panel"	Pages Containing Login Portals	saurabh kode
2023-11-20	inurl:"/wp-includes/user.php" -site:wordpress.org -site:github.com -site:fossies.org	Files Containing Juicy Info	Sathish Kishore
2023-10-20	Fwd: Google Dork: inurl:login/login-user	Files Containing Juicy Info	Faridul Hasan
2023-10-20	intitle:"index of" "/userlist/"	Files Containing Juicy Info	Md.Tariqul Islam Hasanat
2023-10-02	intitle:"index of" "username.txt"	Files Containing Juicy Info	Ranjeet Jaiswal
2023-06-02	inurl:"/login.aspx" intitle:"user"	Pages Containing Login Portals	Sachin Gupta
2023-05-31	Re: inurl:"/user" intitle:"userlogin"	Pages Containing Login Portals	Ishak Hasan Sabbir

> Note: We used google dorks, but these are not limited to these [explore GHDB for more understanding]

Lab 1-o2 Find the Company's Domains, Subdomains, and Hosts using Netcraft and DNSdumpster

Scenario:

You are a Certified Ethical Hacker working for SecureBridge Solutions, a financial technology company specializing in payment processing and fraud prevention systems. SecureBridge's

cybersecurity team recently identified unusual traffic patterns and suspected unauthorized network scanning. The organization’s management is concerned that their publicly exposed web infrastructure might give attackers an entry point to compromise their systems. They have requested a proactive assessment to identify all their internet-facing assets, including domains, subdomains, and hosts

Solution:

Phase 1: Document Scope and Understanding

The initial phase of this assessment focuses on defining the operational scope by identifying anomalous traffic patterns and investigating suspected unauthorized network scanning activities. These indicators suggest potential exposure of internal IP addresses and possible DNS leaks to external entities.

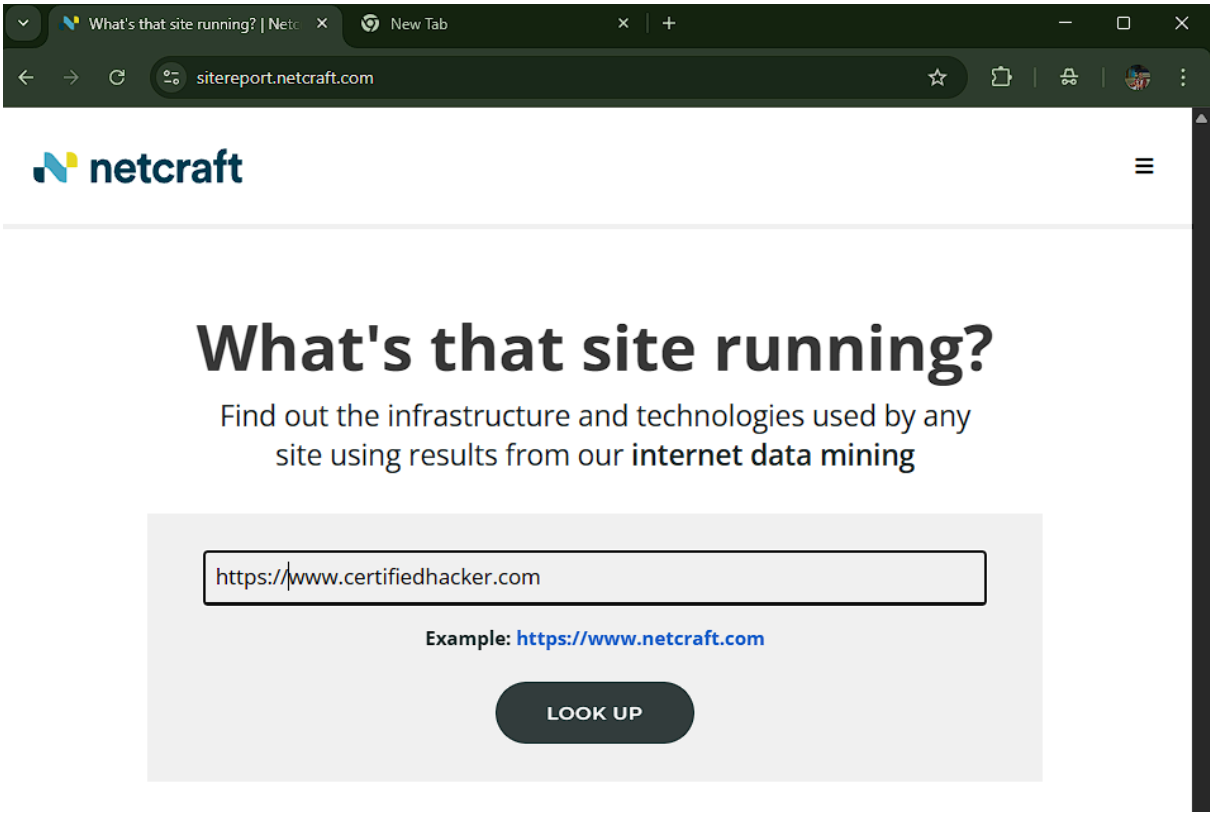
Scope Overview:

To establish a comprehensive understanding of the organization's digital footprint, the following reconnaissance tasks will be executed:

Task	Description
Host Discovery	Identify active hosts within the target infrastructure to determine live systems and potential entry points.
Domain Enumeration	Enumerate all primary domains associated with the organization to map the external attack surface.
Subdomain Discovery	Identify and catalog all subdomains to uncover development servers, staging environments, or forgotten assets that may introduce risk.

Phase 2: Understanding the usage of tools

Using Netcraft and DNSdumpster, two powerful tools for mapping the organization’s public-facing infrastructure. These tools allow us to collect detailed information about the company’s DNS records, subdomains, and associated hosts, which may not be immediately obvious from a casual website inspection.



And by execution for this action we get details for the website: It provides the site report for the **https://www.certifiedhacker.com** website, which includes details about the Fore**ground Information**, **Network details**, **Hosting Company**, and additional information.

Network

Site	https://www.certifiedhacker.com	**Domain**	certifiedhacker.com
Netblock Owner	Unified Layer	**Nameserver**	ns1.bluehost.com
Hosting company	Newfold Digital	**Domain registrar**	networksolutions.com
Hosting country	US	**Nameserver organisation**	whois.domain.com
IPv4 address	162.241.216.11 (VirusTotal)	**Organisation**	Unknown
IPv4 autonomous systems	AS31898	**DNS admin**	dnsadmin@box5331.bluehost.com
IPv6 address	Not Present	**Top Level Domain**	Commercial entities (.com)
IPv6 autonomous systems	Not Present	**DNS Security Extensions**	Enabled
Reverse DNS	box5331.bluehost.com		

IP delegation

IPv4 address (162.241.216.11)

IP range	Country	Name	Description
`::ffff:0.0.0.0/96`	United States	IANA-IPV4-MAPPED-ADDRESS	Internet Assigned Numbers Authority
↳ `162.0.0.0-162.255.255.255`	United States	NET162	Various Registries (Maintained by ARIN)
↳ `162.240.0.0-162.241.255.255`	United States	UNIFIEDLAYER-NETWORK-16	Unified Layer
↳ `162.241.216.11`	United States	UNIFIEDLAYER-NETWORK-16	Unified Layer

Shows the target website's subdomains, rank, netblock, and operating system details.

4 results

Rank	Site	First seen	Netblock	OS	Site Report
5308	www.certifiedhacker.com	December 2002	Unified Layer	Linux	
665651	mail.certifiedhacker.com	January 2017	Unified Layer	Linux	
668034	cpanel.certifiedhacker.com	January 2017	Unified Layer	Linux	
1053124	demo.certifiedhacker.com	April 2024	Unified Layer	unknown	

To find the company's DNS Servers, Geo IP, and domain mapping using the DNSdumpster website we need to go to this url **https://dnsdumpster.com/**.

> Note: Two major tools DNSDumpster and Netcraft are being used for this activity.

Lab 1-o3 Gather Personal Information from Various Social Networking Sites using Sherlock and whois

Scenario:

You are an ethical hacker hired by TechScale Technologies, a multinational cybersecurity solutions provider. Recently, the company discovered an increase in spear-phishing attacks targeting employees in critical roles, such as their Chief Information Security Officer (CISO) and Network Security Architect. TechScale suspects that attackers are gathering personal and

professional details from social networking sites to craft convincing phishing emails and execute social engineering attacks. . The company recently discovered that an unknown entity registered a domain with a similar name, “TechSale.com,” potentially targeting their clients with phishing attacks. Concerned about the risk of domain spoofing and intellectual property misuse, the company’s management has asked you to investigate the suspicious domain and assess its origin and ownership details.

Solution:

Phase 1: Document Scope and Understanding

This phase focuses on understanding the scope of identified threats, specifically the increase in sophisticated spear-phishing campaigns targeting organizational employees. The objective is to analyze the methods used by threat actors to harvest employee information and construct convincing lures.

Key Observations:

Threat Vector	Methodology	Indicators
Spear-Phishing Campaigns	Attackers are extracting employee usernames and email addresses through Google dorking techniques and search engine enumeration.	Unusual emails referencing internal projects or roles.
Social Media Profiling	Identified employee names are cross-referenced and enriched using data from social media platforms (e.g., LinkedIn, Twitter, Facebook).	Targeted messages referencing personal interests, job history, or recent posts.
Personal Information Aggregation	Threat actors gather detailed personal information from private profiles and public interactions to craft highly authentic and context-aware phishing lures.	Emails that mimic internal communication styles or reference non-public personal details.

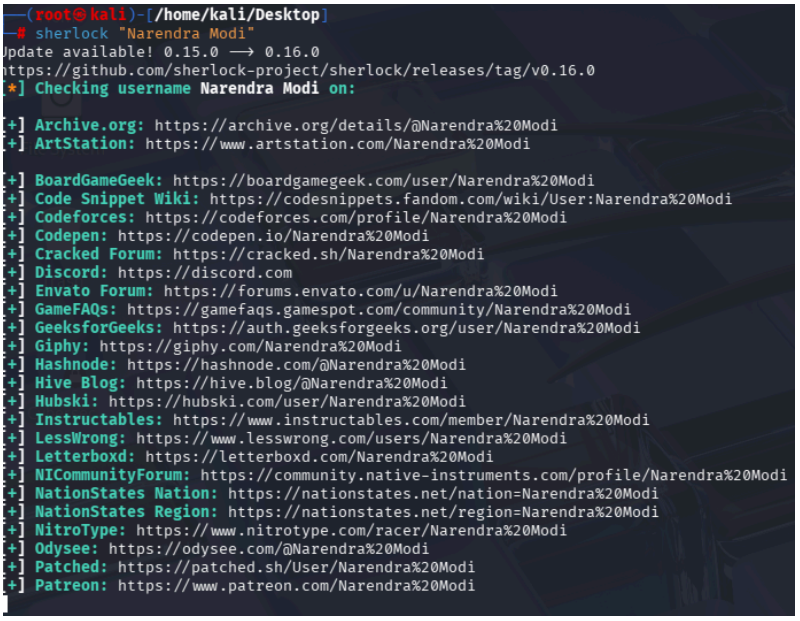
Phase 2: Using Sherlock To Enumerate Online Profiles

Sherlock is a Python application that looks through social media platforms to find details about a specific person. Sherlock searches numerous social networking sites for a specific target user, locates the person, and displays the results along with the complete URL linked to the target person.

Through this exercise, you identify that some employees share detailed job descriptions, personal achievements, and even organizational updates on their social media profiles. For instance, the Security Architect has publicly shared details about an upcoming project, inadvertently revealing information about the company’s technologies and tools.

By completing this lab, you will gain practical experience gathering information through social networking sites and provide TechSaleTechnologies with a report detailing the exposed information, associated risks, and recommendations. Suggestions may include

implementing social media guidelines, conducting security awareness training, and limiting the amount of professional information shared publicly.



```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# sherlock "Narendra Modi"
Update available! 0.15.0 ──> 0.16.0
https://github.com/sherlock-project/sherlock/releases/tag/v0.16.0
[*] Checking username Narendra Modi on:

[+] Archive.org: https://archive.org/details/@Narendra%20Modi
[+] ArtStation: https://www.artstation.com/Narendra%20Modi

[+] BoardGameGeek: https://boardgamegeek.com/user/Narendra%20Modi
[+] Code Snippet Wiki: https://codesnippets.fandom.com/wiki/User:Narendra%20Modi
[+] Codeforces: https://codeforces.com/profile/Narendra%20Modi
[+] Codepen: https://codepen.io/Narendra%20Modi
[+] Cracked Forum: https://cracked.sh/Narendra%20Modi
[+] Discord: https://discord.com
[+] Envato Forum: https://forums.envato.com/u/Narendra%20Modi
[+] GameFAQs: https://gamefaqs.gamespot.com/community/Narendra%20Modi
[+] GeeksforGeeks: https://auth.geeksforgeeks.org/user/Narendra%20Modi
[+] Giphy: https://giphy.com/Narendra%20Modi
[+] Hashnode: https://hashnode.com/@Narendra%20Modi
[+] Hive Blog: https://hive.blog/@Narendra%20Modi
[+] Hubski: https://hubski.com/user/Narendra%20Modi
[+] Instructables: https://www.instructables.com/member/Narendra%20Modi
[+] LessWrong: https://www.lesswrong.com/users/Narendra%20Modi
[+] Letterboxd: https://letterboxd.com/Narendra%20Modi
[+] NICommunityForum: https://community.native-instruments.com/profile/Narendra%20Modi
[+] NationStates Nation: https://nationstates.net/nation=Narendra%20Modi
[+] NationStates Region: https://nationstates.net/region=Narendra%20Modi
[+] NitroType: https://www.nitrotype.com/racer/Narendra%20Modi
[+] Odysee: https://odysee.com/@Narendra%20Modi
[+] Patched: https://patched.sh/User/Narendra%20Modi
[+] Patreon: https://www.patreon.com/Narendra%20Modi
```

> Note: you can download pipx > sherlock-project or direct sherlock form sudo apt-get install sherlock

---

Lab 1-04: Perform Whois Lookup using DomainTools

Scenario:

You are an ethical hacker hired by TechSales Dynamics, a technology firm specializing in secure application development. The company recently discovered that an unknown entity registered a domain with a similar name, “rnicrosoft.com,” potentially targeting their clients with phishing attacks. Concerned about the risk of domain spoofing and intellectual property misuse, the company’s management has asked you to investigate the suspicious domain and assess its origin and ownership details.

Solution:

Phase 1: Document Scope and Understanding

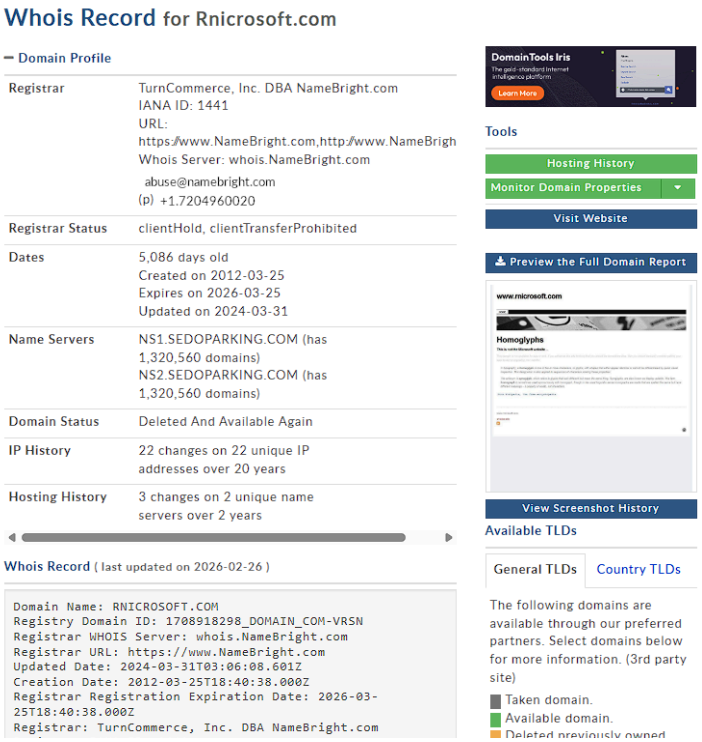
This phase addresses the identified threat of domain spoofing and the registration of lookalike domains. The objective is to assess origin mismatches, verify ownership details, and identify potential tampering with domain registration records that could facilitate phishing or brand impersonation attacks.

Key Observations:

Threat Vector	Description	Potential Impact
Domain Spoofing	Attackers register domains with slight variations of the legitimate organization domain (e.g., eccounciI.org vs. eccouncil.org).	Phishing emails appearing to originate from trusted domains.
Lookalike Domains	Domains utilizing homoglyphs, typosquatting, or alternative TLDs (e.g., .net, .co, .org) to impersonate the brand.	Credential harvesting, malware distribution, and brand dilution.
Ownership Tampering	Suspicious modifications to WHOIS records, including privacy protection services or mismatched registrant details.	Difficulty in takedown efforts and attribution of malicious infrastructure.

Phase 2: Using WHOIS To Address the authenticity of the new site

- Open any browser and go to the **http://whois.domaintools.com**.
- Type the websites name to check its vitals



- To obtain more target Whois information, use other Whois lookup tools like Batch IP Converter (http://www.sabsoft.com), SmartWhois (https://www.tamos.com), etc.

> Note: check further for who is commands on terminal

Lab 1-05: Gather DNS Information using nslookup Command Line Utility and Online Tool

Scenario:

A company has hired you to test its network infrastructure penetration. You must gather information about the company's Domain Name System (DNS) configuration as part of your assessment. You must use a command-line tool and a web app to perform the task. You need to gather the target domain's IP address and DNS information.

Solution:

Phase 1: Starting with nslookup

This section outlines the methodology for DNS enumeration using the `nslookup` utility. DNS interrogation can be performed via two primary methods:

1. **Command-Line Interface (CLI):** Utilizing the native `nslookup` tool available on Windows and Linux systems.
2. **Web-Based Interface:** Accessing online DNS lookup tools such as http://kloth.net/services/nslookup.php for quick, platform-independent queries.

DNS enumeration is a critical reconnaissance technique used to map an organization's infrastructure, identify potential entry points, and uncover misconfigurations that could be exploited by threat actors.

Phase 1.1: DNS Record Types: Technical Overview and Attacker Utility

The following table details the various DNS record types, their intended usage, and how an attacker might leverage them during the reconnaissance phase.

Record Type	Description	Legitimate Usage	Attacker Utility / Enumeration Purpose
A	Maps a domain name to an IPv4 address.	Directing web traffic to a web server.	Identify IP addresses of target servers for port scanning and vulnerability assessment.
AAAA	Maps a domain name to an IPv6	Directing traffic to IPv6-enabled servers.	Discover IPv6 infrastructure

Record Type	Description	Legitimate Usage	Attacker Utility / Enumeration Purpose
	address.		that may be less monitored or misconfigured compared to IPv4.
ANY	Returns all known records for a domain.	Comprehensive DNS lookup for troubleshooting.	Gather a complete overview of the domain's DNS configuration in a single query. *(Note: Many servers now restrict ANY queries.)*
CNAME	Canonical Name; aliases one domain to another.	Pointing `www.example.com` to `example.com`.	Map the structure of subdomains and identify third-party services (e.g., CDNs, cloud platforms) hosting organizational assets.
NS	Name Server; specifies the authoritative DNS servers for a domain.	Delegating a domain to specific DNS hosts.	Identify DNS server providers. Weaknesses in these servers could lead to zone transfers or cache poisoning.
MX	Mail Exchange; specifies mail servers for the domain.	Routing email to the correct mail server.	Discover mail server addresses for targeted phishing campaigns or password spraying attacks.
PTR	Pointer; maps an IP address to a domain name (reverse lookup).	Verifying that an IP address belongs to the claimed domain.	Identify domains hosted on shared IPs and map IP

Record Type	Description	Legitimate Usage	Attacker Utility / Enumeration Purpose
			ranges back to organizational assets.
SOA	Start of Authority; contains administrative information about the zone.	Providing zone metadata (primary NS, admin contact, serial number).	Extract the zone serial number to determine if the zone has been recently updated, indicating potential system changes.
TXT	Text records; stores arbitrary text data.	Domain verification (SPF, DKIM, DMARC), ownership verification.	Harvest SPF/DKIM records to understand email security controls. Extract any inadvertently stored sensitive data.
LOC	Location; specifies geographic location information for a domain.	Associating a domain with a physical location.	Geographically locate servers to understand the organization's physical infrastructure footprint.
RP	Responsible Person; specifies the email address of the person responsible for the domain.	Providing administrative contact information.	Identify potential targets for social engineering or administrative account compromise.
SRV	Service records; defines the host and port for specific services.	Locating services like SIP, LDAP, or XMPP.	Discover internal services (e.g., Kerberos, LDAP) that may be exposed or misconfigured.

Record Type	Description	Legitimate Usage	Attacker Utility / Enumeration Purpose
AXFR	Zone Transfer; replicates DNS records between servers.	Synchronizing DNS data between primary and secondary servers.	**CRITICAL:** If misconfigured, an attacker can request a full copy of the zone file, revealing all hosts, subdomains, and IP addresses associated with the domain.

NSLookup CLI Methodology

The following commands illustrate how to utilize `nslookup` interactively to enumerate the DNS records described above.

1. Entering Interactive Mode:

bash

```
nslookup
> server <target_dns_server>  (Optional: Specify a DNS server, e.g., 8.8.8.8)
> set type=<record_type>
> <target_domain>
```

2. Record Type Enumeration Examples:

Record Type	Command	Purpose
A	`> set type=A> eccouncil.org`	Resolve the domain to its IPv4 address.
AAAA	`> set type=AAAA> eccouncil.org`	Resolve the domain to its IPv6 address.
ANY	`> set type=ANY> eccouncil.org`	Retrieve all available DNS records (if permitted).
CNAME	`> set type=CNAME> www.eccouncil.org`	Identify aliases and their canonical names.
NS	`> set type=NS> eccouncil.org`	List the authoritative name servers.
MX	`> set type=MX> eccouncil.org`	Identify the mail exchange servers.
PTR	`> set type=PTR> <IP_address>`	Perform a reverse lookup on an IP address.
SOA	`> set type=SOA> eccouncil.org`	Retrieve the Start of Authority record.

Record Type	Command	Purpose
TXT	`> set type=TXT> eccouncil.org`	Retrieve text records (SPF, DKIM, etc.).
LOC	`> set type=LOC> eccouncil.org`	Retrieve geographic location data (rarely configured).
RP	`> set type=RP> eccouncil.org`	Identify the responsible person's contact (rare).
SRV	`> set type=SRV> _sip._tcp.eccouncil.org`	Locate specific services (requires service/port knowledge).
AXFR	`> set type=AXFR> eccouncil.org`	**Attempt a zone transfer.** If successful, this yields a complete map of the domain.

3. Zone Transfer Attempt (Critical Test):

bash

```
nslookup
> server <name_server_from_NS_lookup>
> set type=AXFR
> <target_domain>
```

Risk Assessment

Finding	Risk Level	Implication
Successful AXFR (Zone Transfer)	**Critical**	Full infrastructure disclosure; attacker gains complete network map.
Exposed SRV Records	Medium	May reveal internal services not intended for public disclosure.
SPF/TXT Misconfigurations	Medium	Weak email authentication can facilitate spoofing.
Inconsistent A/AAAA Records	Low	May indicate shadow IT or unauthorized assets.

Mitigation Recommendations

- **Restrict Zone Transfers:** Configure DNS servers to allow AXFR requests only from authorized secondary servers.
- **Minimize Information Disclosure:** Avoid storing sensitive data in TXT records and limit publicly accessible DNS data to essential records only.
- **Monitor DNS Responses:** Regularly audit DNS configurations to ensure no unintended information leakage occurs.
- **Implement DNSSEC:** Deploy DNS Security Extensions to authenticate DNS responses and prevent tampering.

> Note: you can go both ways and those ways works the same

Lab 1-06: Perform Network Tracerouting in Windows and Linux Machines

Scenario:

A company has hired you to test its network infrastructure penetration. As part of your assessment, you need to identify any potential vulnerabilities. You have to use the traceroute tool, which can be used to trace the route that network packets take from one location to another. Perform the task on both Windows and Linux machines.

Solution:

Phase 1: Initiating request with Tracert command

As part of the network infrastructure penetration test, the assessment requires identifying potential vulnerabilities through path discovery and hop-by-hop analysis. Due to architectural differences between Windows and Linux operating systems, the traceroute utility may produce varying results. A comprehensive analysis necessitates executing the tool on both platforms to ensure complete visibility into the network path.

Methodology:

1. Windows-Based Traceroute (tracert)

- Open the Command Prompt on the Windows assessment machine.
- Execute the following command to trace the route to the target domain:

  text

  ```
  tracert google.com
  ```

- The utility will display the series of routers (hops) traversed by packets en route to the destination, along with their corresponding IP addresses and response times.
- To review additional configuration options and parameters, execute:

  text

  ```
  tracert /?
  ```

2. Linux-Based Traceroute (traceroute)

- Launch the Mate terminal on the ParrotOS assessment machine.

- Execute the following command to perform the path discovery:

  text

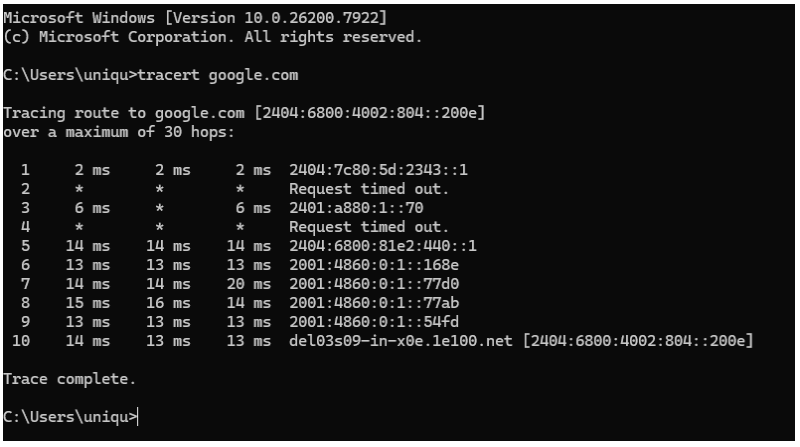
  ```
  traceroute google.com
  ```

- The output will enumerate the IP addresses of each hop along the path to the destination. Note that due to differences in the underlying implementation (ICMP vs. UDP probes), the results may differ from the Windows tracert output.

3. Alternative Traceroute Utilities

In addition to native command-line tools, the following specialized applications can provide enhanced visualization and analysis capabilities:

- **Traceroute NG** (SolarWinds): Available at https://www.solarwinds.com
- **Visual Route**: Available at http://visualroute.com



```
Microsoft Windows [Version 10.0.26200.7922]
(c) Microsoft Corporation. All rights reserved.

C:\Users\uniqu>tracert google.com

Tracing route to google.com [2404:6800:4002:804::200e]
over a maximum of 30 hops:

  1     2 ms     2 ms     2 ms  2404:7c80:5d:2343::1
  2     *        *        *     Request timed out.
  3     6 ms     *        6 ms  2401:a880:1::70
  4     *        *        *     Request timed out.
  5    14 ms    14 ms    14 ms  2404:6800:81e2:440::1
  6    13 ms    13 ms    13 ms  2001:4860:0:1::168e
  7    14 ms    14 ms    20 ms  2001:4860:0:1::77d0
  8    15 ms    16 ms    14 ms  2001:4860:0:1::77ab
  9    13 ms    13 ms    13 ms  2001:4860:0:1::54fd
 10    14 ms    13 ms    13 ms  del03s09-in-x0e.1e100.net [2404:6800:4002:804::200e]

Trace complete.

C:\Users\uniqu>
```

> Note: Understand the closed open and filtered routes

Lab 1-07: Gather Information about a Target by Tracing Emails using eMailTrackerPro

Scenario:

You are an ethical hacker hired by Techsec Solutions, a cybersecurity consulting firm, to investigate a recent spear-phishing attempt targeting their employees. The phishing email, disguised as a message from the company's HR department, attempted to harvest login credentials by directing recipients to a malicious website. To analyze the origin and intent of the phishing campaign, you have been tasked with tracing the email and gathering detailed information about its sender using eMailTrackerPro, an email analysis tool.

Solution:

Phase 1: Instaling eMailTrackerPro

Prepare the Windows 11 virtual machine by installing the necessary dependencies for eMailTrackerPro.

Step 1.1: Install Java Runtime Environment (JRE)

1. Open a web browser and navigate to the official Java download page:

   text

   ```
   https://www.java.com/en/download/manual.jsp
   ```

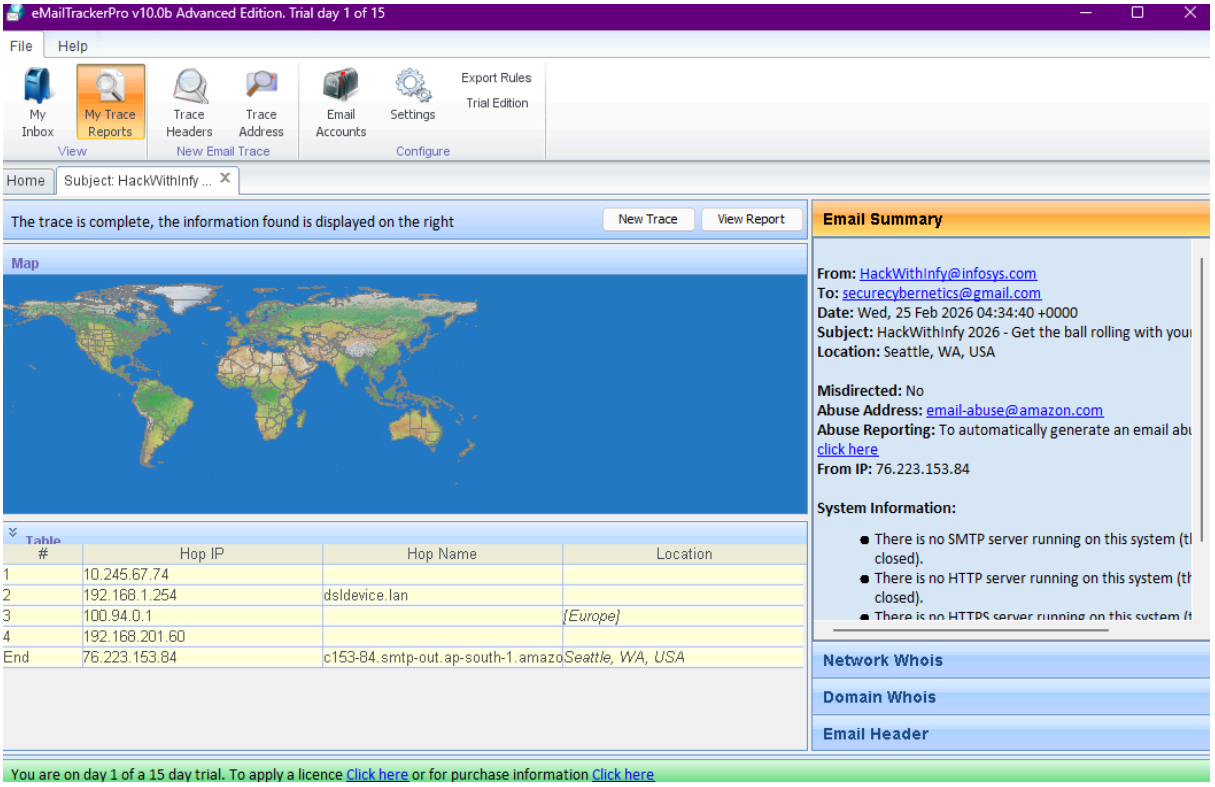
2. Select **Windows Offline** and download the installer.
3. Navigate to the **Downloads** folder and double-click on the executable file (e.g., `jre-8u431-windows-i586.exe`).

Step 1.2: Download and Install eMailTrackerPro

1. Return to the browser and navigate to the download source:

   ```
   https://emailtrackerpro.software.informer.com/download/
   ```

Phase 2: Tracing the email



> Note: Address the header from outlook mail or from the email

Lab 1-08: Footprinting a Target using Recon-ng

Scenario:

A company has hired you to perform a security assessment of their web applications. The company has several web applications that are publicly accessible, and they want you to identify any potential vulnerabilities that attackers could exploit. You are required to use a powerful tool to footprint a target website.

Solution:

Phase 1: Read More detail about recon-ng here:

- Cyberary - Tools and Cheat Sheet (Courseware)

Phase 2: Installation & Setup

```
# On Kali/Parrot Linux
sudo apt-get install recon-ng
recon-ng

# Via pip
pip install recon-ng
```

Phase 3: Core Recon-ng Workflow

Step 1 — Create a workspace:

```
[recon-ng][default] > workspaces create target_company
```

Step 2 — Add your target domain:

```
[recon-ng][target_company] > db insert domains
domain (TEXT): eccouncil.org
```

Step 3 — Install modules from the marketplace:

```
[recon-ng][target_company] > marketplace install recon/domains-ho
sts/hackertarget
[recon-ng][target_company] > marketplace install recon/domains-co
ntacts/whois_pocs
[recon-ng][target_company] > marketplace install recon/hosts-host
s/resolve
```

Step 4 — Run a module:

```
[recon-ng][target_company] > modules load recon/domains-hosts/hac
kertarget
[recon-ng][target_company][hackertarget] > options set SOURCE ecc
ouncil.org
[recon-ng][target_company][hackertarget] > run
```

Step 5 — View collected data:

```
[recon-ng][target_company] > show hosts
[recon-ng][target_company] > show contacts
```

Step 6 — Generate an HTML report:

```
[recon-ng][target_company] > marketplace install reporting/html
[recon-ng][target_company] > modules load reporting/html
[recon-ng][target_company][html] > options set CREATOR YourName
[recon-ng][target_company][html] > run
```

Phase 4: Key Modules Reference

Module	Purpose
`recon/domains-hosts/hackertarget`	Subdomain discovery
`recon/domains-contacts/whois_pocs`	Extract WHOIS contacts
`recon/hosts-hosts/resolve`	Resolve hostnames to IPs
`recon/domains-hosts/brute_hosts`	Brute-force subdomains
`reporting/html`	Generate HTML report

> **Note:** Always use Recon-ng within authorized engagements only.

Lab 1-09: Footprinting a Target using ShellGPT

Scenario:

While working in a security solutions company, you are tasked with mapping digital footprints from social media data. You decide to use AI to analyze digital footprints, and the AI will identify patterns and highlight privacy risks. AI-powered tools perform footprinting, significantly simplifying the process of information gathering.

Solution:

Phase 1: Understanding ShellGPT

ShellGPT is a command-line tool that integrates GPT-based AI models into your terminal workflow. For ethical hackers, it serves as an AI-powered assistant that can help with footprinting tasks — interpreting OSINT data, suggesting next steps, summarizing findings, and generating shell commands.

Key advantages for footprinting:

- Automates repetitive OSINT analysis tasks
- Generates tailored shell commands based on natural language input
- Synthesizes data from multiple sources into readable summaries
- Identifies patterns and privacy risks in collected social media data

Phase 2: Installation

```
pip install shell-gpt
```

After installing, configure your OpenAI API key:

```
export OPENAI_API_KEY="your_api_key_here"
```

Or for persistent configuration:

```
sgpt --api-key your_api_key_here
```

Phase 3: Footprinting Workflow with ShellGPT

Step 1 — Ask ShellGPT to generate a recon command:

```
sgpt "Give me a shell command to find all subdomains of example.c
om using subfinder"
```

Step 2 — Pipe real tool output directly into ShellGPT for analysis:

```
nmap -sV target.com | sgpt "Analyze this nmap output and highligh
t security risks"
```

Step 3 — Summarize WHOIS or DNS data:

```
whois example.com | sgpt "Summarize key registration details and
flag anything suspicious"
```

Step 4 — Analyze social media footprint:

```
cat linkedin_scrape.txt | sgpt "Identify patterns and privacy ris
ks in this employee data"
```

Step 5 — Generate a footprinting report:

```
cat recon_notes.txt | sgpt "Create a structured footprinting repo
rt with risk ratings from these notes"
```

Phase 4: AI-Assisted Pattern Recognition

ShellGPT excels at identifying non-obvious patterns in aggregated OSINT data:

Use Case	ShellGPT Prompt Example
Employee exposure analysis	"What personal info in this LinkedIn data could be used for spear-phishing?"
Tech stack identification	"Identify technologies and versions from this HTTP header data"
Email pattern discovery	"Derive likely email formats from these employee names and domain"
Risk prioritization	"Rank these exposed assets by exploitation risk"

> **Note:** ShellGPT requires a valid OpenAI API key. Always use AI-assisted tools responsibly and within authorized scope. AI analysis supplements — but does not replace — manual verification of findings.

✅ Lab Completion Tracker

Lab	Topic	Status
1-01	Google Hacking Techniques	✅ Complete
1-02	Netcraft & DNSdumpster	✅ Complete
1-03	Sherlock & Whois	✅ Complete
1-04	DomainTools WHOIS	✅ Complete
1-05	nslookup & DNS Enumeration	✅ Complete
1-06	Traceroute (Windows & Linux)	✅ Complete
1-07	eMailTrackerPro	✅ Complete
1-08	Recon-ng	✅ Complete
1-09	ShellGPT	✅ Complete

> **Disclaimer : Using the notes is for educational prepose only, the owner is not responsible for any mis conduct by the reader**